

CONTRAT_GEN

Documentation technique

Architecture, fonctionnement interne et maintenance

Pour l'installateur et le développeur

Édition du 17 septembre 2026

Sommaire

- | | |
|-------------------------------------|---------------------------------|
| 1. Architecture générale | 8. Mails |
| 2. Principes de conception | 9. Sécurité |
| 3. Structure du projet | 10. Routes |
| 4. Machine à états et journal | 11. Installation et déploiement |
| 5. Stockage : le disque est la base | 12. Exploitation |
| 6. Configuration d'une instance | 13. Tests |
| 7. Moteur de contrats | 14. Étendre une instance |
-

1. Architecture générale

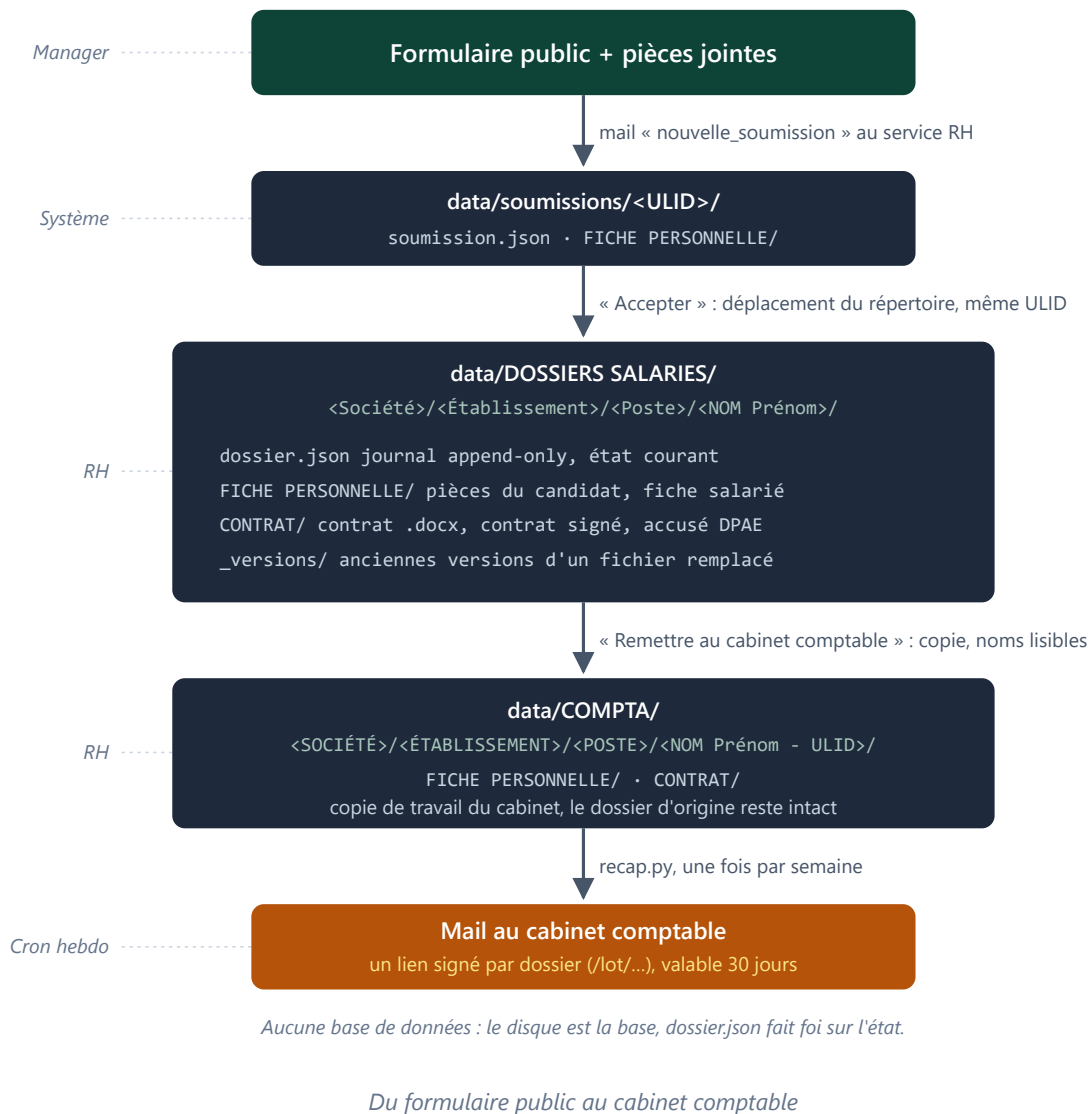
Principe fondamental

Un client = une copie du dépôt. Le code est le produit ; l'instance (configuration + données) vit à part et n'est jamais versionnée. Aucune donnée n'est mutualisée entre clients.

Stack

Couche	Technologie
Runtime	Python 3.12
Framework web	Flask, templates Jinja2
Serveur WSGI	Waitress en production (mono-process, 4 threads) ; Werkzeug en développement (<code>DEBUG=1</code>)
Contrats	python-docx (modèles <code>.docx</code>), htmldocx (modèles <code>.html</code>), num2words (montants en lettres)
Signature électronique	Yosign, optionnel, désactivé par défaut
Stockage	Fichiers JSON et arborescence disque. Aucune base de données.
Dépendances	<code>requirements.txt</code> , versions épinglées

Flux



2. Principes de conception

2.1 Le disque est la source de vérité

`dossier.json` fait foi sur l'état : c'est la dernière entrée `vers` du journal. Un fichier présent sur disque (contrat, accusé) est un indice, jamais une preuve d'état. Le journal ne fait que croître.

2.2 Mono-process obligatoire

`store._verrou(uid)` est un verrou de thread : il n'exclut qu'à l'intérieur d'un process. Deux serveurs sur le même stockage perdraient des entrées de journal en silence. Waitress est mono-process par construction ;

ne jamais lancer `gunicorn` avec plusieurs workers ni `waitress-serve --processes`. Les plafonds de rate-limit vivent aussi en mémoire du process.

2.3 Configuration pure données

Tout ce qui varie d'un client à l'autre vit dans `config/` : JSON, modèles de contrats, modèles de mails. Aucun `.py` n'y entre. L'application ne réécrit jamais sa configuration ; seul `configurer.py compte` ajoute un compte dans `instance.json`.

2.4 Garde-fou au démarrage

`config.verifier()` refuse de servir tant que la configuration est incomplète ou dangereuse :

- version de configuration incompatible ;
- secret HMAC encore à sa valeur d'exemple ;
- compte RH au mot de passe d'exemple, aucun compte, ou bloc `utilisateurs` malformé ;
- aucun établissement déclaré ;
- `mails.rh` ou `mails.expediteur` vide, `url` publique vide (les liens du mail hebdomadaire partiraient vides) ;
- rôle du formulaire inconnu ou pointant un champ inexistant, règle `derives` malformée ;
- jeton d'un modèle de contrat sans source ;
- poste sans modèle de contrat, grille de salaire incomplète ;
- bloc `stockage` ou `conservation` malformé, dossier de stockage inexistant ou non inscriptible.

Le même contrôle s'exécute au rechargement à chaud : une configuration invalide est refusée et l'ancienne reste active.

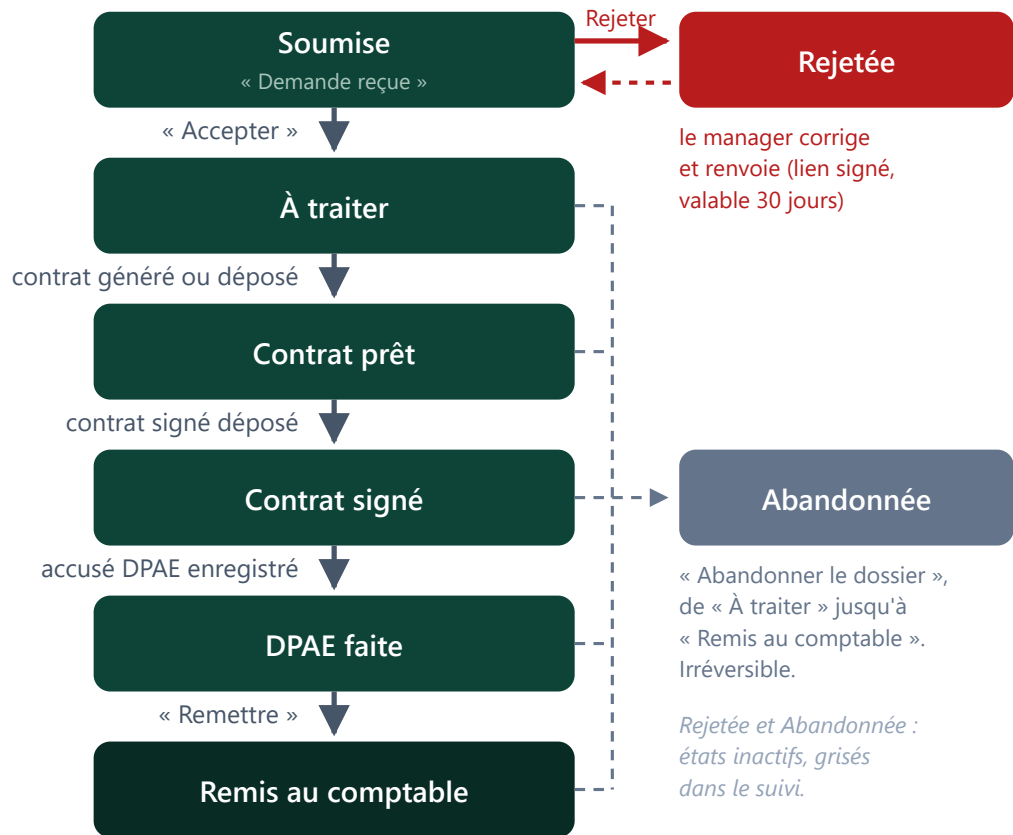
3. Structure du projet

```
Contrat_Gen/
├─ app.py           # Routes Flask, parcours, rate-limit, verrou multi-machine
├─ store.py         # Stockage disque, ULID, journal, transitions, liens signés, purge
├─ contrat.py       # Moteur de remplissage des modèles (.docx / .html -> .docx)
├─ config.py        # Lecture de config/, cache, garde-fou verifier()
├─ mails.py         # Rendu des modèles .txt, envoi SMTP ou console
├─ signature.py     # Signature électronique Yousign (optionnel)
├─ installer.py     # Crée l'instance d'un nouveau client
├─ configurer.py   # Bilan de la config, assistant, comptes, test SMTP
├─ placeholders.py  # Fiche des {{Jetons}} valides, dérivée de la config
├─ doctor.py        # Génère un contrat d'essai par croisement de la config
├─ recap.py         # Mail hebdomadaire au cabinet comptable (cron)
├─ purger.py        # Aperçu de la purge en ligne de commande (lecture seule)
├─ demo.py          # Démo sur config.demo/ et data_demo/
├─ templates/       # 9 pages Jinja2 (formulaire, login, suivi, dossier, lot...)
├─ config/          # Instance de démonstration versionnée (fixture des tests)
├─ config.exemple/  # Squelette copié par installer.py
├─ config.demo/     # Configuration riche pour demo.py (modèles HTML, grille)
├─ data/            # Données de production (jamais versionné)
├─ data_demo/       # Données de la démo, effacées à chaque lancement
├─ docs/            # Guides Markdown et PDF (docs/pdf/build.py)
└─ tests/           # Suite de tests, sans framework : python tests/test_x.py
```

Responsabilités et dépendances internes

Module	Responsabilité	Importe
app.py	Routes, contrôle d'accès, rate-limit, effets de bord des transitions (mails, fiche, contrat)	config, store, contrat, mails, signature
store.py	Répertoires, journal, transitions permises, noms de fichiers lisibles, copie comptable, liens HMAC, purge	config
contrat.py	Valeurs des jetons, règles dérivées, formats, génération .docx	config
config.py	Chargement JSON, rôles du formulaire, mentions, grille, garde-fou	contrat, store (imports locaux : le cycle est assumé)
mails.py	Modèles .txt , transport SMTP (STARTTLS vérifié) ou console	config, store

4. Machine à états et journal



États et transitions, tels que définis dans `store.py`

États

```
ETATS = ["Soumise", "Rejetee", "ATraiter", "ContratPret", "ContratSigne",  
         "DpaeFaite", "RemisComptable", "Abandonnee"]  
INACTIFS = {"Rejetee", "Abandonnee", "RemisComptable"} # grisés dans le suivi
```

Transitions permises

`store.transition()` est le point de passage unique ; une transition absente de la table lève `ValueError`, même sur un POST forgé.

```
TRANSITIONS = {  
    "Soumise": {"Abandonnee"},  
    "Rejetee": {"Abandonnee"},  
    "ATraiter": {"ContratPret", "Abandonnee"},  
    "ContratPret": {"ContratSigne", "Abandonnee"},  
    "ContratSigne": {"DpaeFaite", "Abandonnee"},  
    "DpaeFaite": {"RemisComptable", "Abandonnee"},  
    "RemisComptable": {"Abandonnee"},  
}
```

Trois passages ne transitent pas par cette table car ils changent de répertoire ou de zone : `store.valider()` (Soumise → ATraiter, la soumission devient un dossier salarié), `store.rejeter()` (→ Rejetee) et `store.resoumettre()` (Rejetee → Soumise, correction). L'interface n'offre l'abandon qu'à partir de « À traiter ».

Le journal

Chaque entrée porte au minimum `de`, `vers`, `le` (ISO 8601 UTC) et `par`. Une entrée de transition change `vers` ; une entrée d'événement garde `de == vers` et porte un `type`. Extrait réel d'un dossier de la démo :

```
{
  "formulaire_version": 1,
  "id": "01M2N3D8WJAFCD5EG1E15XVNY",
  "champs": {
    "etablissement": "Basilic Café / Paris Bastille",
    "poste": "Equipier Polyvalent",
    "nom_prenom": "BENALI Sarah",
    "date_debut": "2026-10-12",
    "...": "..."
  },
  "link_epoch": 0,
  "lien_comptable_epoch": 0,
  "journal": [
    {
      "de": null,
      "vers": "Soumise",
      "le": "2026-09-16T12:35:02+00:00",
      "par": "formulaire"
    },
    {
      "de": "Soumise",
      "vers": "ATraiter",
      "le": "2026-09-16T12:35:20+00:00",
      "par": "rh"
    },
    {
      "de": "ATraiter",
      "vers": "ContratPret",
      "le": "2026-09-16T12:35:20+00:00",
      "par": "rh",
      "modele": "Equipier.html"
    },
    {
      "de": "ContratPret",
      "vers": "ContratSigne",
      "le": "2026-09-16T12:35:23+00:00",
      "par": "rh"
    },
    {
      "de": "ContratSigne",
      "vers": "DpaeFaite",
      "le": "2026-09-16T12:35:24+00:00",
      "par": "rh"
    },
    {
      "de": "DpaeFaite",
      "vers": "RemisComptable",
      "le": "2026-09-16T12:35:25+00:00",
      "par": "rh"
    },
    {
      "de": "RemisComptable",
      "vers": "RemisComptable",
      "le": "2026-09-16T12:35:29+00:00",
      "type": "acces_lot",
      "par": null,
      "ip": "127.0.0.1"
    }
  ]
}
```

Types d'événements écrits par `store.noter()` : `fiche_salarie`, `fiche_echouee`, `mail_echoue`, `signature_envoyee`, `renvoi_comptable`, `acces_lot`. S'y ajoute `purge`, posé par `store.purger()` au moment où il allège le journal. Un rejet ajoute `motif` et `commentaire` ; une correction ajoute `motif: "correction"`.

DEMANDE REÇUE	✓ A TRAITER	✓ CONTRAT PRET	✓ CONTRAT SIGNE	✓ DPAE FAITE	REMIS AU COMPTABLE
LIEN COMPTABLE					
REFAIRE LA COPIE ET LE LIEN					
Cela révoquera le lien précédent ; le dossier repartira dans le prochain mail hebdomadaire.					

Le journal tel qu'affiché dans la fiche du dossier

5. Stockage : le disque est la base

Arborescence réelle

```
data/
├── .serveur-actif.json           # verrou multi-machine
├── soumissions/<ULID>/         # demandes pas encore acceptées
│   ├── soumission.json
│   └── FICHE PERSONNELLE/      # pièces au nom de leur rôle (identite.pdf, rib.pdf...)
├── DOSSIERS SALARIES/
│   ├── <Société>/<Établissement>/<Poste>/<NOM Prénom>/
│   │   ├── dossier.json       # journal append-only
│   │   ├── FICHE PERSONNELLE/ # pièces renommées, fiche salarié
│   │   ├── CONTRAT/          # contrat .docx, contrat signé, accusé DPAE
│   │   └── _versions/         # fichiers remplacés, horodatés
├── COMPTA/
│   ├── <SOCIÉTÉ>/<ÉTABLISSEMENT>/<POSTE>/<NOM Prénom - ULID>/
│   │   ├── FICHE PERSONNELLE/
│   │   └── CONTRAT/
└── mails/                      # mode console : un .eml par envoi
```

Le premier niveau est le `groupe` de l'établissement (à défaut, le nom de la société). L'acceptation **déplace** le répertoire de `soumissions/` vers `DOSSIERS SALARIES/` en gardant l'ULID ; `soumission.json` devient `dossier.json`. Les clés internes des buckets (`pieces` , `contrat` , `_versions`) sont traduites en noms de répertoires lisibles par `store.BUCKETS`. Un fichier déposé par-dessus un existant est archivé dans `_versions/` avant remplacement.

Le mode `stockage.mode = "dossier"` place `data/` dans un répertoire répliqué par un client de synchronisation (OneDrive, SharePoint) ; le garde-fou vérifie alors que le répertoire existe et accepte l'écriture avant de servir. La variable d'environnement `DONNEES`, si elle est posée sur la ligne de lancement, l'emporte sur ce bloc (`config._donnees()`) : une instance lancée avec `DONNEES=` écrit là, pas sur le drive.

Identifiants

`store.nouvel_id()` produit un ULID : 48 bits de temps en millisecondes puis 80 bits d'aléa, encodés sur 26 caractères en base 32 Crockford (sans I, L, O, U). Triable par date de création, unique sans coordination.

Verrou multi-machine

`.serveur-actif.json` empêche deux serveurs de servir le même stockage :

```
{"hote": "poste-rh", "pid": 12345, "le": 1789562000.0}
```

Sur la même machine, le PID est sondé (vivant ou mort). Depuis une autre machine, le verrou est considéré périmé après 5 minutes sans rafraîchissement. Un démarrage refusé affiche l'hôte qui tient le verrou.

6. Configuration d'une instance

Fichiers

Fichier	Contenu
<code>instance.json</code>	Identité du client, secret HMAC, URL publique, mails, comptes, motifs de rejet, modèles par poste, règles dérivées, saisie RH, stockage, conservation
<code>formulaire.json</code>	Champs du formulaire public et rôles
<code>societes.json</code>	Sociétés, établissements, mentions légales, couloir de contrat, adresses du manager et du cabinet
<code>grille.json</code>	Grille de rémunération (optionnel)
<code>contrats/</code>	Modèles de contrat <code>.docx</code> ou <code>.html</code>
<code>mails/</code>	Modèles de mails <code>.txt</code>
<code>contrats/fiche_salarie.docx</code>	Modèle de la fiche salarié (optionnel ; le fichier vit dans <code>contrats/</code> , la clé <code>fiche_salarie</code> d' <code>instance.json</code> le nomme)
<code>PLACEHOLDERS.md</code>	Fiche des jetons valides, générée par <code>placeholders.py</code> , à remettre au client

instance.json

```
{
  "config_version": 1,
  "client": "Basilic Café",
  "secret": "<64 caractères hexadécimaux, générés par installer.py>",
  "url": "https://embauche.basiliccafe.fr",
  "signature": {"mode": "manuel"},
  "stockage": {"mode": "local"},
  "conservation": {"jours": 1095, "jours_candidature": 730,
    "apres": ["RemisComptable", "Rejetee", "Abandonnee"]},
  "fiche_salarie": "fiche_salarie.docx",
  "mails": {
    "mode": "smtp", "hote": "smtp.basiliccafe.fr", "port": 587,
    "utilisateur": "rh@basiliccafe.fr", "mot_de_passe": "...", "expediteur": "rh@basiliccafe.fr",
    "rh": ["rh@basiliccafe.fr"], "dpae": null, "recap": null,
    "comptable_default": "compta@cabinet.fr"
  },
  "utilisateurs": {"rh": {"mdp_hash": "scrypt:32768:8:1$..."}},
  "motifs_ko": ["Pièce illisible ou manquante", "Informations incohérentes",
    "Établissement ou poste erroné", "Rémunération à revoir", "Autre"],
  "templates": [
    {"quand": {"poste": "Equipier Polyvalent", "temps_partiel": "OUI"},
      "modele": "Equipier_Partiel.html"},
    {"quand": {"poste": "Equipier Polyvalent"}, "modele": "Equipier.html"},
    {"quand": {"poste": "Manager"}, "modele": "Manager.html"}
  ],
  "critiques": ["SalaireChiffres", "SalaireLettres"],
  "saisie_rh": [{"placeholder": "NumeroCarteBTP", "libelle": "N° carte BTP",
    "aide": "au dos de la carte"}],
  "derives": [
    {"placeholder": "Nationalite", "si": ["nationalite", "==", "Autres"],
      "alors": "{NationaliteEtrangere}", "sinon": "française"},
    {"placeholder": "DureeMensuelle", "format": "mensualise", "de": "TempsTravail"}
  ]
}
```

Notes :

- `templates` accepte aussi la forme simple `{"Manager": "Manager.docx"}`. En forme liste, la **première** règle dont tous les `quand` correspondent aux champs du dossier l'emporte : mettre les cas particuliers avant le cas général.
- `stockage.mode` vaut `local` (répertoire `data/` de l'instance) ou `dossier` avec une clé `chemin` (répertoire synchronisé).
- `conservation` absent = aucune purge. `jours` et `jours_candidature` sont des entiers strictement positifs ; `apres` liste des états de `store.ETATS`.
- `critiques` : jetons qui doivent avoir une valeur non vide à la génération, en plus des champs requis du formulaire.
- `saisie_rh` : jetons qu'aucun champ ne fournit ; la RH les saisit sur l'écran « À traiter » avant de générer.

formulaire.json

```
{
  "version": 1,
  "titre": "Formulaire d'embauche",
  "intro": "À remplir par le manager...",
  "champs": [
    {"id": "etablissement", "libelle": "Établissement", "type": "etablissement", "requis": true},
    {"id": "poste", "libelle": "Poste", "type": "choix", "requis": true,
      "options": ["Equipier Polyvalent", "Manager"], "placeholder": "Poste"},
    {"id": "nationalite_etrangere", "libelle": "Nationalité étrangère", "type": "texte",
      "requis_si": ["nationalite", "Autres"], "placeholder": "NationaliteEtrangere"},
    {"id": "cni", "libelle": "Carte Nationale d'Identité (recto-verso)",
      "type": "piece_jointe", "role": "identite", "requis": true, "max_fichiers": 2}
  ],
  "roles": {"nom": "nom_prenom", "email": "email", "date_debut": "date_debut"}
}
```

Types de champs : `etablissement`, `choix`, `texte`, `texte_long`, `date`, `email`, `piece_jointe`.
`placeholder` relie un champ à un jeton des modèles. `requis_si: [champ, valeur]` rend un champ obligatoire, et visible, seulement quand un autre champ vaut cette valeur. `version` est recopié dans chaque dossier (`formulaire_version`) pour lire un vieux dossier après un changement de formulaire.

Tout champ `piece_jointe` doit porter un `role` — c'est lui, et non l' `id`, qui nomme le fichier sur disque (`identite.pdf`, puis « Identité - NOM Prénom.pdf » une fois le dossier ouvert) et qui permet de reconnaître une pièce déjà déposée. Un champ `piece_jointe` sans `role` n'est pas rattrapé par le garde-fou : il lève un `KeyError` au premier affichage du suivi. `store.LIBELLES_PIECE` donne un libellé humain aux rôles connus (`identite`, `carte-vitale`, `rib`, `contrat`, `contrat-signé`, `accuse-dpae`, `fiche-salarie`) ; un rôle absent de cette table sert de libellé tel quel. `max_fichiers` (défaut 1) autorise plusieurs fichiers pour un même rôle : le premier garde le nom nu, les suivants prennent un suffixe `_2`, `_3` ...

Ce `role` -là nomme une **pièce jointe** ; à ne pas confondre avec les **rôles du formulaire** ci-dessous, qui désignent les champs que le moteur sait lire.

Rôles du formulaire

Le moteur ne lit **aucun identifiant de champ en dur** ; il passe par un vocabulaire fermé de rôles déclarés dans `roles` :

Rôle	Obligatoire	Usage
<code>etablissement</code>	oui	Mentions légales, cabinet, couloir de contrat, arborescence
<code>poste</code>	oui	Modèle de contrat, grille de salaire, arborescence
<code>nom</code>	oui	Nom du répertoire, noms de fichiers, mails
<code>email</code>	oui	Email du candidat ; repli du lien de correction si l'établissement n'a pas de <code>manager_email</code>
<code>prenom</code> , <code>nom_usage</code>	non	Identité quand nom et prénom sont saisis séparément
<code>date_debut</code>	non	Colonne « Début », alerte de retard, alerte CDD

Un rôle non déclaré retombe sur son identifiant historique (`etablissement` , `poste` , `nom_naissance` , `email_demandeur` , `date_debut` ...) : une configuration sans `roles` garde le comportement d'origine.

`societes.json`

```
[
  {
    "nom": "Basilic Café",
    "siren": "789 456 123",
    "comptable_email": "compta@cabinet.fr",
    "mentions": { "RaisonSociale": "BASILIC CAFE SAS", "RCS": "RCS Paris 789 456 123",
      "SiegeSocial": "...", "ConventionCollective": "..."},
    "etablissements": [
      { "nom": "Paris Bastille", "siret": "789 456 123 00014", "contrat": "genere",
        "manager_email": "bastille@basiliccafe.fr", "groupe": "RESTAURANTS",
        "mentions": { "AdresseEtablissement": "..."}},
      { "nom": "Lyon Confluence", "siret": "789 456 123 00022", "contrat": "depose"}
    ]
  }
]
```

`contrat` vaut `genere` ou `depose` et fixe le couloir. `manager_email` reçoit les liens de correction.
`comptable_email` reçoit le récapitulatif hebdomadaire de la société (repli : `mails.comptable_default`).

`grille.json`

Un objet : `champ_heures` à la racine (l'id du champ du formulaire qui porte la durée hebdomadaire), et une liste `postes` où chaque ligne prend l'une des deux formes — forfait mensuel, ou barème par durée :

```
{
  "champ_heures": "temps_travail",
  "postes": [
    {"poste": "Manager", "mensuel": 2800},
    {"poste": "Equipier",
      "bareme": {"24": {"chiffres": "1 480,08",
                        "lettres": "mille quatre cent quatre-vingts euros et huit centimes"},
                 "35": {"chiffres": "1 801,80", "lettres": "..."}}}
  ]
}
```

Le poste du dossier est rapproché d'une ligne par mots normalisés, la plus spécifique gagnant : « Equipier Polyvalent » prend la ligne « Equipier », « Assistant Manager » ne prend pas celle de « Manager ». `mensuel` l'emporte sur `bareme` s'ils cohabitent ; les montants du barème sont servis tels quels, sans recalcul, pour qu'aucun arrondi ne diverge du contrat papier.

Le garde-fou refuse un barème qui ne couvre pas toutes les options du champ d'heures, et refuse deux postes du formulaire qui retomberaient sur la même ligne (le second sortirait au tarif du premier, sans rien signaler).

7. Moteur de contrats

Principe

`contrat.remplir()` est le point d'entrée : il calcule les valeurs de tous les jetons puis remplace chaque `{{Jeton}}` du modèle. Un modèle `.docx` est traité paragraphe par paragraphe avec python-docx (les runs sont préservés) ; un modèle `.html` est rempli en texte puis converti en `.docx` par htmldocx. **Le contrat généré est toujours un `.docx`.**

Sources des valeurs

Source	Exemples
Champs du formulaire (<code>placeholder</code> du champ)	<code>{{NomPrenom}}</code> , <code>{{DateDebut}}</code> , <code>{{TempsTravail}}</code>
Mentions de la société et de l'établissement	<code>{{RaisonSociale}}</code> , <code>{{Siret}}</code> , <code>{{AdresseEtablissement}}</code>
Grille de salaire	<code>{{SalaireChiffres}}</code> , <code>{{SalaireLettres}}</code>
Saisie RH (<code>saisie_rh</code>)	<code>{{NumeroCarteBTP}}</code>
Règles dérivées (<code>derives</code>)	<code>{{Nationalite}}</code> , <code>{{DureeMensuelle}}</code> , <code>{{BlocAutorisationTravail}}</code>
Calculées par le moteur	<code>{{Aujourd'hui}}</code> , dates en toutes lettres
Pièces	<code>{{PiecesFournies}}</code> , <code>{{PiecesManquantes}}</code> (fiche salarié)

Règles dérivées

Deux formes, évaluées dans l'ordre du fichier (une règle peut utiliser un jeton calculé par une règle précédente) :

```
{"placeholder": "DureeMensuelle", "format": "mensualise", "de": "TempsTravail"}
```

```
{"placeholder": "BlocAutorisationTravail",  
"si": ["nationalite", "=", "Autres"],  
"alors": "<p>Titre « {{TypeAutorisation}} » valable jusqu'au {{DateFinValidite}}.</p>",  
"sinon": ""}
```

Formats disponibles : `lettres` (nombre en toutes lettres, centimes compris), `mensualise` (heures hebdomadaires × 52 / 12), `nombre` (« 24H » → « 24 »), `majuscules`, `date_longue`.

Vérification

- `config.verifier()` refuse au démarrage tout jeton d'un modèle actif sans source.
- `python doctor.py` génère réellement un contrat pour chaque croisement (poste × temps partiel × établissement...) et signale les cas sans modèle ou avec une valeur vide.
- `python placeholders.py` écrit `PLACEHOLDERS.md`, la liste exacte des jetons valides pour cette instance, à remettre au client qui balise ses modèles.

8. Mails

Modèles

Un fichier `.txt` par mail dans `config/mails/` : la première ligne `Objet: ...`, puis le corps. Les `{jetons}` sont ceux passés par le code à `mails.envoyer()`.

Modèle	Déclencheur	Destinataire
<code>nouvelle_soumission</code>	Envoi ou correction du formulaire	<code>mails.rh</code>
<code>rejet</code>	Rejet par la RH	<code>manager_email</code> de l'établissement, repli : email du formulaire
<code>rappel_dpae</code>	Acceptation de la demande	<code>mails.dpae</code> , repli : <code>mails.rh</code>
<code>recap_hebdo</code>	<code>recap.py</code> (cron)	<code>comptable_email</code> de chaque société, copie <code>mails.recap</code> ou <code>mails.rh</code>

Transport

Mode	Comportement
<code>console</code>	Écrit un <code>.eml</code> dans <code>data/mails/</code> et l'affiche sur la sortie standard
<code>smtp</code>	Envoi réel : STARTTLS avec vérification du certificat, puis authentification si <code>utilisateur</code> est renseigné

La variable d'environnement `MAILS_MODE` surclasse `mails.mode`. Un échec d'envoi n'interrompt jamais l'action métier : il est journalisé (`type: mail_echoue`) et signalé à l'écran.

9. Sécurité

Authentification et session

Comptes dans `instance.json` → `utilisateurs`, mots de passe hachés par `werkzeug.security` (scrypt). Session Flask signée par le secret de l'instance, cookie `HttpOnly`, `SameSite=Lax`, `Secure` hors `DEBUG`, durée 12 heures.

L'écran de connexion

Rate-limit et honeypot

Point d'entrée	Plafond	Fenêtre glissante
Formulaire public et correction (<code>POST /</code> , <code>POST /corriger/...</code>)	10 envois par adresse IP	5 minutes
Connexion (<code>POST /login</code>)	10 tentatives par adresse IP	15 minutes

Le champ caché `website` du formulaire est un honeypot : rempli, la demande est acceptée en apparence mais ignorée. L'adresse IP vient de `X-Forwarded-For` uniquement si `PROXIES` déclare le nombre réel de reverse proxies ; sinon l'en-tête est ignoré.

Liens signés

Les liens de correction et les liens du cabinet sont signés HMAC-SHA256 avec le secret de l'instance :

```
<usage>.<ULID>.<horodatage d'émission>.<epoch>.<signature tronquée à 32 hex>
```

`store.verifier_lien()` contrôle la signature, l'usage, l'âge (30 jours) et l'`epoch` du dossier. Incrémenter l'`epoch` révoque tous les liens émis : `link_epoch` à chaque rejet, `lien_comptable_epoch` au renvoi, à l'abandon et à la purge. Chaque accès à un lot est journalisé avec l'adresse IP.

Dossier BENALI Sarah

Basilic Café / Paris Bastille | Equipier Polyvalent | début 12/10/2026 | 01H2N5E344QB3Q2V48QYKF65ZH

[TOUT TÉLÉCHARGER \(.ZIP\)](#)

8 fichier(s)

FICHIERS DU DOSSIER

- 📄 Accusé DPAE - BENALI SARAH - 2026-09-16.pdf
- 📄 Contrat - BENALI SARAH - 2026-09-16.docx
- 📄 Contrat signé - BENALI SARAH - 2026-09-16.pdf
- 📄 Carte vitale - BENALI SARAH - 2026-09-16.pdf
- 📄 Identité - BENALI SARAH - 2026-09-16.pdf
- 📄 Identité_2 - BENALI SARAH - 2026-09-16.pdf
- 📄 RIB - BENALI SARAH - 2026-09-16.pdf

La page du lot, accessible par le seul lien signé

Téléversements

Liste blanche d'extensions (`.pdf` , `.jpg` , `.jpeg` , `.png` ; `.docx` en plus pour les contrats), **15 Mo par fichier** (`store.TAILLE_MAX` , vérifié après écriture d'un temporaire) et 40 Mo par requête (`MAX_CONTENT_LENGTH`), noms de fichiers reconstruits par l'application (jamais le nom envoyé). Les fichiers sont servis avec `X-Content-Type-Options: nosniff` .

10. Routes

Publiques

Méthode	Route	Rôle
GET, POST	/	Formulaire de demande (POST classique ou <code>fetch</code> avec en-tête <code>X-Requested-With</code>)
GET, POST	/corriger/<jeton>	Correction d'une demande rejetée
GET	/lot/<jeton>	Page du dossier pour le cabinet
GET	/lot/<jeton>/zip	Archive du dossier
GET	/lot/<jeton>/fichier/<bucket>/<nom>	Un fichier du dossier
GET, POST	/login · GET /logout	Session RH

Espace RH (session requise)

BA Basilic Café — Démo

SUIVI D'EMBAUCHE

SALARIÉS

rh — quitter

Demandes d'embauche

3 en attente d'action

4 affichées

triées par date de début

1 dossier(s) ont dépassé leur durée de conservation — leurs pièces peuvent être effacées. Voir la purge.

1

ÉTAT

Tous

▼

Tous

▼

FILTRE

2

SALARIÉ	ÉTABLISSEMENT	POSTE	DÉBUT	ÉTAT	DERNIÈRE ACTIVITÉ	PIÈCES MANQUANTES
NKEMBA Awa	Basilic Café / Paris Bastille	Manager	01/10/2026	● Contrat prêt	aujourd'hui	—
BENALI Sarah	Basilic Café / Paris Bastille	Equipier Polyvalent	12/10/2026	● Soumise	aujourd'hui	—
SOARES Rui	Basilic Café / Lyon Confluence	Equipier Polyvalent	19/10/2026	● À traiter	aujourd'hui	—
MARTIN Léa	Basilic Café / Paris Bastille	Equipier Polyvalent	02/11/2026	● Soumise	aujourd'hui	—

3

PURGER LES DOSSIERS TERMINÉS

RECHARGER LA CONFIGURATION

Le suivi, point d'entrée de l'espace RH

Contrat_Gen — Documentation technique

18 / 24

Méthode	Route	Rôle
GET	/suivi	Dossiers en cours (tout sauf RemisComptable), filtres établissement et état
GET	/salaries	Dossiers remis au comptable, groupés par établissement
GET	/dossier/<uid>	Fiche d'un dossier
GET	/dossier/<uid>/fichier/<bucket>/<nom>	Téléchargement d'un fichier
POST	/dossier/<uid>/valider	Accepter : ouvre le dossier, fiche salarié, rappel DPAE, contrat si couloir généré
POST	/dossier/<uid>/rejeter	Rejeter : motif, commentaire, mail avec lien de correction
POST	/dossier/<uid>/contrat	Générer le contrat (saisie RH, ou reprise après échec)
POST	/dossier/<uid>/contrat-depose	Déposer le contrat (couloir déposé)
POST	/dossier/<uid>/contrat-signé	Déposer le contrat signé
POST	/dossier/<uid>/signature-envoyer , .../signature-verifier	Signature électronique (si activée)
POST	/dossier/<uid>/dpae-faite	Enregistrer l'accusé DPAE
POST	/dossier/<uid>/remettre	Remettre au cabinet : copie dans COMPTA/
POST	/dossier/<uid>/renvoyer	Refaire la copie et révoquer le lien du cabinet
POST	/dossier/<uid>/abandonner	Abandonner
GET, POST	/purger	Aperçu puis exécution de la purge
POST	/recharger	Recharger la configuration

11. Installation et déploiement

Nouveau client

```

pip install -r requirements.txt
python installer.py "Basilic Café" /srv/basilic
# stockage dans un dossier synchronisé :
python installer.py "Basilic Café" /srv/basilic "C:/Users/rh/OneDrive - Basilic/Embauches"

```

L'installateur copie `config.exemple/` vers `/srv/basilic/config/`, génère le secret HMAC et un mot de passe RH initial (affiché en fin d'installation, à changer avec `configurer.py compte`), et écrit le bloc `stockage`. Il reste à remplir la configuration :

```
CONFIG_DIR=/srv/basilic/config python configurer.py          # bilan : ce qui manque
CONFIG_DIR=/srv/basilic/config python configurer.py --assister # assistant interactif
CONFIG_DIR=/srv/basilic/config python placeholders.py        # fiche des jetons pour le client
CONFIG_DIR=/srv/basilic/config python doctor.py              # couverture des modèles
```

Lancement

```
CONFIG_DIR=/srv/basilic/config DONNEES=/srv/basilic/data python app.py # production (waitress)
DEBUG=1 python app.py          # développement (werkzeug)
```

Variable	Défaut	Rôle
<code>CONFIG_DIR</code>	<code>config/</code>	Répertoire de configuration de l'instance
<code>DONNEES</code>	<code>data/</code> à côté de <code>config/</code>	Répertoire de données ; l'emporte sur <code>stockage.chemin</code> , y compris en mode <code>dossier</code>
<code>HOST</code> , <code>PORT</code>	<code>127.0.0.1</code> , <code>5000</code>	Adresse et port d'écoute
<code>PROXIES</code>	<code>0</code>	Nombre de reverse proxies devant l'application ; active la lecture de <code>X-Forwarded-For</code>
<code>DEBUG</code>	absent	Serveur de développement, cookie sans <code>Secure</code>
<code>MAILS_MODE</code>	absent	Surclasse <code>mails.mode</code> (<code>console</code> ou <code>smtp</code>)

Reverse proxy

L'application écoute en local ; un reverse proxy porte le TLS et transmet l'IP d'origine.

```
# Caddy
embauche.basiliccafe.fr {
    reverse_proxy localhost:5000
}
```

Lancer alors avec `PROXIES=1`. Waitress efface par défaut les en-têtes `X-Forwarded-*` non déclarés : `PROXIES` est lu par `app.py` pour configurer waitress **et** Flask, un réglage seul ne suffit pas.

Tâche hebdomadaire

```
CONFIG_DIR=/srv/basilic/config DONNEES=/srv/basilic/data python recap.py
```

À planifier une fois par semaine (cron, tâche planifiée Windows). Sans cette tâche, les dossiers remis n'arrivent jamais au cabinet.

Sauvegarde et mise à jour

```
tar czf sauvegarde-$(date +%F).tar.gz /srv/basilic/config /srv/basilic/data
```

Restaurer = décompresser et relancer. Mettre à jour = remplacer le code (`git pull`) et relancer : `config/` et `data/` ne sont jamais modifiés par le code, il n'y a rien à migrer.

12. Exploitation

Besoin	Commande ou écran
Vérifier la configuration	<code>python configurer.py</code> (bilan), garde-fou au démarrage
Tester l'envoi de mail	<code>python configurer.py mail votre@adresse</code>
Ajouter un compte RH	<code>python configurer.py compte identifiant</code>
Vérifier les modèles de contrat	<code>python doctor.py</code>
Recharger la configuration sans redémarrer	Bouton « Recharger la configuration » du suivi (<code>POST /recharger</code>)
Voir ce que la purge effacerait	<code>python purger.py</code> (lecture seule) ; <code>/purger</code> dans l'application pour exécuter
Suivre ce que fait le serveur	Sortie standard : les deux lignes de démarrage et les erreurs Python. Waitress ne journalise pas les requêtes — l'historique métier est le journal de chaque dossier
Mails en mode console	<code>data/emails/*.eml</code>

[← Toutes les demandes](#)

Purge des dossiers terminés

Conservation : 1 jours après un état terminal (RemisComptable, Rejetee, Abandonnee) · candidatures jamais validées 1 jours.

1 DOSSIER(S) À PURGER

Les pièces (CNI, RIB, contrats, copies comptables) seront **effacées définitivement**. Le journal du dossier est conservé, le répertoire est renommé `purge-<id>`. Action irréversible.

SALARIÉ	ÉTABLISSEMENT	ÉTAT	ANCIENNETÉ
DUPONT JEAN	Basilic Café / Paris Bastille	Remis au comptable	2 j / 1 j

[PURGER CES 1 DOSSIER\(S\)](#)

L'aperçu de purge : lecture d'abord, écriture seulement au clic

Le démarrage refuse de servir si un autre serveur tient le verrou du stockage, si la configuration est invalide, ou si le dossier de stockage synchronisé n'est pas accessible en écriture. Le message d'erreur nomme la cause.

13. Tests

Aucun framework : chaque fichier est un script exécutable, la suite est verte quand tous sortent avec le code 0.

```
python tests/test_parcours.py      # les deux couloirs de bout en bout, fiche, récap
python tests/test_ecrans.py        # rendu de chaque écran dans chaque état
python tests/test_formulaire.py    # soumission fetch (JS) du formulaire public
python tests/test_pieces_multi.py  # pièces multi-fichiers (recto/verso)
python tests/test_valeurs_contrat.py # valeurs imprimées dans le contrat (grille, mensualisation)
python tests/test_produit.py       # garde-fou, fiche salarié, version de configuration
python tests/test_clients.py       # deux instances isolées, étanchéité multi-client
python tests/test_login.py         # rate-limit, session, PROXIES à travers waitress
python tests/test_mails.py         # mode console, surcharge, STARTTLS vérifié
python tests/test_configurer.py   # bilan, assistant, comptes, test SMTP
python tests/test_doctor.py        # couverture de configuration
python tests/test_purge.py         # éligibilité, effacement, journal conservé
python tests/test_signature.py     # Yousign contre un transport factice
```

Les tests utilisent `config/` (fixture versionnée, client fictif) ou construisent une configuration temporaire. `test_clients.py` vérifie que tout nouveau module racine est bien couvert : y ajouter tout nouveau `.py` à la racine.

14. Étendre une instance

Ajouter un champ au formulaire

1. Ajouter l'entrée dans `formulaire.json` → `champs` (identifiant, libellé, type, `requis` ou `requis_si`).
2. S'il alimente un jeton : `"placeholder": "MonJeton"`, puis `{{MonJeton}}` dans les modèles.
3. S'il joue un rôle pour le moteur (nom, email, date de début) : le déclarer dans `roles`.
4. `python placeholders.py` puis `python doctor.py`, et « Recharger la configuration ».

Ajouter un modèle de contrat

1. Déposer le `.docx` ou `.html` dans `config/contrats/`.
2. L'associer dans `instance.json` → `templates`, en forme liste si le choix dépend d'autres champs :
`json {"quand": {"poste": "Equipier Polyvalent", "type_contrat": "CDD"}, "modele": "Equipier_CDD.html"}`
3. `python doctor.py` pour vérifier que chaque croisement a un modèle et aucune valeur vide.

Ajouter un établissement, une société, un compte

- Établissement : `societes.json` → `etablisements` (nom, SIRET, `contrat`, `manager_email`), puis « Recharger la configuration ».
- Société : nouvel objet dans `societes.json` avec ses mentions et son `comptable_email`.
- Compte : `python configurer.py compte identifiant`.

Ajouter un mail

1. Créer `config/mails/<nom>.txt` : première ligne `Objet: ...`, puis le corps avec des `{jetons}`.
2. Appeler `mails.envoyer("<nom>", destinataires, **valeurs)` depuis le code.

Personnaliser les motifs de rejet

`instance.json` → `motifs_ko` : la liste s'affiche telle quelle dans le menu du rejet.

Contrat_Gen — édition du 16 septembre 2026